

Module 11 Assignment:

Designing a Vulnerability Management Program

JR Clark (002035589)

NEU DAMG7350 (Spring 2026)

Table of Contents

Introduction 3

Asset Discovery Strategy 3

Scanning Schedule & Tool Selection..... 4

Risk-Based Prioritization Approach 4

Remediation SLAs 5

Reporting & Metrics 6

Integration with Incident Response and SOC..... 7

Conclusion 7

 References..... 8

 Methodology and Use of AI Tools 8

APPENDIX A: Asset Criticality Scoring Table (CIA Triad + Exposure + Compliance)..... 9

APPENDIX B: Prioritization Decision Matrix..... 10

Introduction

The company's recent audit failure—driven by critical vulnerabilities remaining unpatched for months—reflects a familiar pattern in modern security programs. As seen in prior architectural work (Module 5), security failures rarely stem from missing tools. Instead, they emerge from unclear ownership, inconsistent prioritization, and teams that have never practiced how to work together when systems degrade. This vulnerability management program addresses those organizational gaps directly. It establishes a structured, risk-based approach grounded in continuous asset discovery, contextual prioritization, disciplined remediation workflows, and integration with incident response and SOC operations. The goal is to ensure vulnerabilities are remediated before they become audit findings, outages, or customer-impacting incidents.

Asset Discovery Strategy

A reliable vulnerability management program begins with an accurate, continuously updated asset inventory. Hybrid environments introduce complexity: cloud workloads are ephemeral, on-premises systems are long-lived, and SaaS dependencies often fall outside traditional scanning boundaries. Automated discovery through cloud APIs, network scanning, and agent-based reporting ensures full coverage. Each asset is classified using the CIA triad, customer data exposure, and regulatory impact—an approach consistent with the organization's broader security architecture and data-classification practices.

Ownership is explicit. Every asset has a primary and backup technical owner, mirroring the operational readiness model used in disaster recovery planning. This eliminates ambiguity during remediation cycles and ensures continuity when personnel are unavailable. Given that only 45% of organizations report being effective at knowing their attack surface (Ponemon Institute, 2022), this structured approach directly addresses a known industry weakness.

Scanning Schedule & Tool Selection

A disciplined scanning schedule is essential for maintaining visibility across a hybrid environment. This program uses differentiated frequencies based on asset type, operational criticality, and exposure. External perimeter systems are scanned weekly to detect internet-facing risks early. Internal servers are scanned biweekly, balancing coverage with operational stability. Cloud workloads are monitored continuously using cloud-native scanners (e.g., AWS Inspector, Azure Defender), which provide real-time detection aligned with the ephemeral nature of cloud resources. Container images are scanned during each CI/CD build and weekly in registries to prevent vulnerable images from propagating into production. Web applications undergo monthly dynamic testing and additional scans after major releases.

Tool selection reflects the need for both breadth and depth. Network and host scanning is performed using platforms such as Nessus or Qualys, which provide authenticated and unauthenticated scanning capabilities. Authenticated scans deliver deeper insight into missing patches, insecure configurations, and privilege issues, while unauthenticated scans simulate an attacker's external perspective. Cloud-native scanners supplement these tools by identifying vulnerabilities in managed services, serverless functions, and container orchestration layers. Application-layer scanning uses tools such as OWASP ZAP or Burp Suite to identify web-specific issues including injection, authentication weaknesses, and misconfigurations.

Risk-Based Prioritization Approach

CVSS provides the baseline severity score, but it is insufficient on its own. ManageEngine notes that CVSS quantifies inherent technical severity but does not account for business context or asset value (ManageEngine, n.d.). N-able similarly emphasizes that CVSS

must be supplemented with environmental and organizational factors to reflect real-world risk (N-able, n.d.). This program therefore layers additional factors on top of CVSS: exploitability intelligence (e.g., EPSS and active exploitation data), CIA-triad impact, customer data exposure, and regulatory obligations.

Regulatory impact is especially important for an e-commerce company handling payment data and customer identities. CyberSierra highlights that fintech-adjacent organizations must navigate PCI DSS, CPRA, and financial-data protection requirements, making vulnerabilities affecting regulated data significantly higher risk (CyberSierra, n.d.). InnReg reinforces that compliance failures can lead to enforcement actions, operational constraints, and reputational damage (InnReg, n.d.). Incorporating regulatory impact into prioritization ensures these vulnerabilities receive accelerated remediation even when their CVSS score alone may not indicate the highest severity.

A full scoring model and decision matrix are included in Appendix A and Appendix B.

Remediation SLAs

Clear, enforceable SLAs ensure timely remediation and prevent the backlog conditions that contributed to the audit failure. SLAs are tied to both severity and exploitability, reflecting the organization's risk-based prioritization model.

- **Critical vulnerabilities with active exploitation:** remediation within **72 hours**
- **Other critical vulnerabilities:** remediation within **7 days**
- **High-severity vulnerabilities:** remediation within **30 days**
- **Medium-severity vulnerabilities:** remediation within **90 days**
- **Low-severity vulnerabilities:** remediation within **180 days**

Exceptions require documented compensating controls, a defined expiration date, and approval from both Security and the business owner. All exceptions are reviewed during monthly governance meetings to ensure they remain valid.

Accountability mirrors the operational model used in disaster recovery: each vulnerability is assigned to the asset owner and backup owner, and overdue critical issues automatically escalate to Incident Response leadership. This ensures remediation is not a best-effort activity but a governed operational process with clear ownership and escalation paths.

Reporting & Metrics

Effective reporting is essential for maintaining remediation discipline and addressing one of the primary barriers identified in the Ponemon research: difficulty tracking whether vulnerabilities are being patched in a timely manner (Ponemon Institute, 2022). This program uses a structured reporting model that provides actionable insights to technical teams, management, and executive leadership.

Weekly operational dashboards track mean time to remediate (MTTR) by severity, SLA compliance, and the distribution of aging vulnerabilities across 30-, 60-, 90-, and 180-day thresholds. These metrics highlight bottlenecks, identify teams that may require additional support, and surface systemic issues such as recurring misconfigurations or patch-deployment failures. Dashboards also monitor coverage of authenticated scans, ensuring the organization maintains deep visibility into asset health rather than relying solely on external or unauthenticated perspectives.

Monthly reports provide trend analysis, including SLA compliance over time, recurrence rates, and cloud vs. on-premises vulnerability distribution. These insights help leadership

understand where risk is concentrated, how remediation performance is evolving, and whether additional investment or process changes are required.

AI-enabled analytics tools can further enhance reporting by automating data aggregation, identifying anomalies, and highlighting emerging patterns that may not be immediately visible in raw metrics. While AI does not replace human judgment, it can accelerate analysis and support more proactive decision-making by surfacing areas that warrant closer investigation.

This reporting structure ensures that vulnerability management is not a passive activity but a measurable, governed process with clear accountability and continuous improvement.

Integration with Incident Response and SOC

Vulnerability management must be closely integrated with SOC and IR functions. This program integrates directly with SOC monitoring and incident response workflows.

Vulnerabilities with known active exploitation trigger IR review, and SOC detection rules are updated based on penetration-testing findings and newly discovered weaknesses. This mirrors the cross-functional readiness model used in disaster recovery drills: practiced workflows, clear escalation paths, and shared situational awareness.

By embedding vulnerability management into continuous monitoring, the organization moves from reactive patching to proactive defense.

Conclusion

This vulnerability management program addresses the root causes of the organization's audit failure: unclear ownership, insufficient prioritization, and lack of operational discipline. By combining continuous asset discovery, contextual risk scoring, structured SLAs, and SOC/IR integration, the program ensures vulnerabilities are remediated based on real-world business impact—not just technical severity. The approach aligns with industry research, regulatory

expectations, and the organization's broader security architecture, creating a sustainable, repeatable, and audit-ready vulnerability management capability.

Equally important, the program should not be implemented as a top-down mandate. Long-term success requires applying an organizational change-management framework that identifies all stakeholders, clarifies their roles, and involves them early in the design and rollout process. Engaging engineering, DevOps, compliance, and business owners in co-creating workflows builds alignment and shared accountability. Ultimately, people—not frameworks—ensure consistent remediation, timely escalation, and adherence to SLAs. Embedding change-management practices ensures the program becomes an operational habit rather than a security-driven directive imposed from above.

References

CyberSierra. (n.d.). *Regulatory compliance for fintech: A complete guide*.
<https://cybersierra.co/blog/regulatory-compliance-for-fintech-a-complete-guide/>

InnReg. (n.d.). *Fintech compliance guide for CEOs and founders*.
<https://www.innreg.com/blog/fintech-compliance-guide-for-ceos-and-founders>

ManageEngine. (n.d.). *Vulnerability management overview: What is vulnerability management?*
<https://www.manageengine.com/vulnerability-management/articles/vulnerability-management-overview.html>

N-able. (n.d.). *Understanding CVE and CVSS: How to evaluate vulnerabilities and manage risks strategically*. <https://www.n-able.com/blog/understanding-cve-cvss-evaluate-vulnerabilities-manage-risks-strategically>

Ponemon Institute. (2022). *The state of vulnerability management in DevSecOps*. Rezilion.

Sawant, A. (2026). *Vulnerability Assessment and Penetration Testing* [Online course]. Coursera & Northeastern University.

Methodology and Use of AI Tools

I completed all analysis, design decisions, and vulnerability management logic independently. Microsoft Copilot was used only as a writing aid to help organize sections and to build tables in the appendices based on criteria and scoring rules I provided. All interpretations, prioritization models, and conclusions reflect my own understanding of the course material and external research. I reviewed and validated all AI-assisted content for accuracy and compliance with Northeastern University's Academic Integrity and Use of AI policy.

APPENDIX A: Asset Criticality Scoring Table (CIA Triad + Exposure + Compliance)

Asset	C	I	A	Customer Exposure	Regulatory Impact	Total Score	Criticality
Payment Gateway	3	3	3	3	3	15	Critical
Customer Database	3	3	2	3	3	14	Critical
E-commerce Frontend	2	2	3	2	2	11	High
Internal Analytics	2	2	2	1	1	8	Medium
Marketing Site	1	1	1	0	0	3	Low

APPENDIX B: Prioritization Decision Matrix

This appendix demonstrates how CVSS severity, exploitability in the wild, and CIA-triad-based asset criticality combine to drive concrete remediation priorities and SLAs. It shows that not all “Critical” findings are treated equally and that medium-severity issues on highly sensitive assets can still receive elevated attention when warranted by business impact.

B.1. Decision Matrix Logic

CVSS Severity	Exploited in Wild?	Asset Criticality (Score)	Priority Level	SLA
Critical	Yes	Critical (13–15)	P1 – Emergency	72 hours
Critical	No	High (10–12)	P1 – Urgent	7 days
High	Yes	Medium (7–9)	P2 – High	14 days
High	No	Medium (7–9)	P3 – Standard	30 days
Medium	Any	Low (5–6)	P4 – Planned	90 days
Low	Any	Any	P5 – Backlog/Accept	180 days

B.2. Example Mappings

Example Vulnerability	CVSS	Exploited in Wild?	Asset	Asset Criticality	Resulting Priority	SLA
RCE in payment API	9.8 (Critical)	Yes	Payment Gateway	15 (Critical)	P1 – Emergency	72 hours
SQLi in customer profile service	9.0 (Critical)	No	Customer Database	14 (Critical)	P1 – Urgent	7 days
Privilege escalation on internal reporting server	8.0 (High)	Yes	Internal Analytics	8 (Medium)	P2 – High	14 days
XSS on marketing site	6.5 (Medium)	No	Marketing Site	3 (Low)	P4 – Planned	90 days
Outdated library on internal dev tool	3.5 (Low)	No	Internal Tooling	5 (Low)	P5 – Backlog/Accept	180 days